

IT Risk Assessment Report

Executive Security Risk Overview

Prepared by: Mulalo Tharaga

Date: 9 August 2026

Assessment type: Personal, self-assessment

1. Executive Summary

This IT risk assessment evaluates the security exposure of the assessed technology environment by reviewing ten assets and ten identified vulnerabilities across devices, systems, applications, networks, cloud services, and stored data. The assessment considers the confidentiality, integrity, and availability of information, together with the likelihood and impact of each risk. The results indicate a high overall level of exposure: six risks are rated Critical, the average risk score is 17.70, and several departments contain assets with medium-to-high risk levels. The most significant concerns include account compromise, phishing and social engineering, weak password practices, malware or ransomware, unpatched software, data loss, insecure network configurations, and unauthorised disclosure of information. Immediate attention should be given to critical vulnerabilities through stronger authentication, timely patching, secure configuration, access control, endpoint protection, and reliable tested backups. Implementing the prioritised treatment plan and conducting regular monitoring and reassessment will reduce residual risk, improve resilience, and support the secure and reliable use of IT assets.

Key Findings

- **Total Assets:** 10
- **Total Vulnerabilities:** 10
- **Critical Risks:** 6
- **Average Risk Score:** 17.70
- Multiple departments contain medium- to high-risk assets.

2. Purpose and Objectives

The purpose of this assessment is to identify, evaluate, and prioritise cybersecurity risks affecting organisational IT assets. The assessment aims to identify assets, threats, vulnerabilities, and existing controls; evaluate risks using a consistent likelihood-and-impact methodology; identify critical and high-risk vulnerabilities; assess compliance; prioritise remediation activities; and provide actionable recommendations to strengthen the organisation's overall security posture. The assessment also establishes a basis for ongoing monitoring and periodic review of cybersecurity risks.

3. Scope

The assessment covers organisational IT assets, including endpoints, servers, network infrastructure, applications, databases, cloud services, and data storage. It evaluates asset criticality, vulnerabilities, associated risks, risk levels, risk scores, compliance status, and potential impacts on the confidentiality, integrity, and availability of organisational information and systems. The assessment also considers departmental risk exposure and remediation priorities. Personal devices, personal accounts, and unrelated external infrastructure are outside the scope of the assessment.

4. Assessment Method

The assessment follows a simplified risk process: establish context, identify assets and threats, identify vulnerabilities and controls, estimate likelihood and impact, determine risk level, select a treatment, and monitor the result. This structure is informed by NIST SP 800-30 Rev. 1 and ISO/IEC 27005:2022. Ratings are qualitative: Low, Medium, High, and Critical. Each risk should be reassessed after treatment to determine its residual level.

Asset Risk Overview

The chart illustrates differences in average risk scores across the assessed IT assets. Several assets show elevated risk levels, indicating greater exposure to security threats and potential operational impact. These higher-risk assets should be prioritised for detailed investigation and timely vulnerability remediation, while lower-risk assets should continue to be monitored to ensure that their risk levels remain within acceptable limits.

Department Risk Analysis

The IT department has the highest average risk score, with Finance ranking second. This concentration of risk indicates that remediation efforts should initially prioritise these two departments. Addressing their most significant vulnerabilities and strengthening relevant controls will help reduce the organisation's overall risk exposure. Other departments should remain subject to ongoing monitoring and periodic reassessment to prevent emerging risks from escalating.

Vulnerability Distribution

The pie chart shows that most identified vulnerabilities fall within the Critical category, demonstrating a substantial concentration of severe security weaknesses. These vulnerabilities require immediate remediation to reduce the likelihood of exploitation and minimise potential operational, financial, and information-security impacts. High- and medium-rated vulnerabilities should then be addressed according to their risk priority, while lower-rated issues should remain subject to ongoing monitoring.

5. Risk Register

ID	Risk scenario	Likelihood	Impact	Initial level	Recommended treatment
R1	Phishing or social engineering leads to account takeover or financial fraud.	High	High	Critical	Use multifactor authentication, verify requests independently, avoid unexpected links, and enable account alerts.
R2	Reused or weak passwords expose multiple accounts after a data breach.	High	High	Critical	Use a password manager and unique, long passwords; replace reused credentials first.
R3	Device loss or theft exposes personal information.	Medium	High	High	Enable screen locks, device encryption, remote locate or wipe, secure backups, and minimal local storage.
R4	Malware or ransomware causes data loss or unauthorised access.	Medium	High	High	Keep systems updated, use security protection, install trusted software only, and maintain protected backups.
R5	Hardware failure or accidental deletion causes permanent loss of documents and photos.	Medium	High	High	Maintain two backup copies on different media or services and test restoration quarterly.
R6	Unpatched or unsupported software is exploited.	Medium	High	High	Enable automatic updates, remove unused applications, and replace unsupported devices or software.
R7	Insecure home Wi-Fi permits unauthorised access or traffic interception.	Medium	Medium	Medium	Use WPA2 or WPA3, a strong router password, current firmware, a guest network, and disable remote administration.
R8	Excessive sharing, insecure cloud settings, or compromised services expose personal data.	Medium	High	High	Review permissions, minimise sensitive uploads, secure cloud accounts, and remove obsolete shared links.

6. Prioritised Treatment Plan

Immediate (0–30 Days)

- Patch critical vulnerabilities.
- Enable Multi-Factor Authentication.
- Remove inactive user accounts.
- Review administrator privileges.

Short-Term (1–3 Months)

- Perform regular vulnerability scans.
- Implement security awareness training.
- Improve asset inventory management.

Long-Term (3–12 Months)

- Deploy continuous monitoring.
- Strengthen incident response procedures.
- Conduct periodic penetration testing.
- Review compliance controls regularly.

Business Impact	
Impact Area	Business Impact
Operational	System disruption, reduced productivity, and delays to critical business activities.
Financial	Remediation costs, potential fraud losses, regulatory penalties, and lost revenue.
Reputational and Compliance	Loss of stakeholder trust, regulatory non-compliance, and damage to the organisation's reputation.

7. Monitoring and Review

- Monthly: review security alerts, failed login notifications, device updates, and unusual financial activity.
- Quarterly: test a backup restoration, review important account recovery methods, and remove unnecessary applications and access permissions.
- Annually: repeat the full risk assessment and update the asset inventory and risk register.

- After a major change or incident: reassess affected risks whenever a device is replaced, a new cloud service is adopted, an account is compromised, or important personal circumstances change.

8. Conclusion

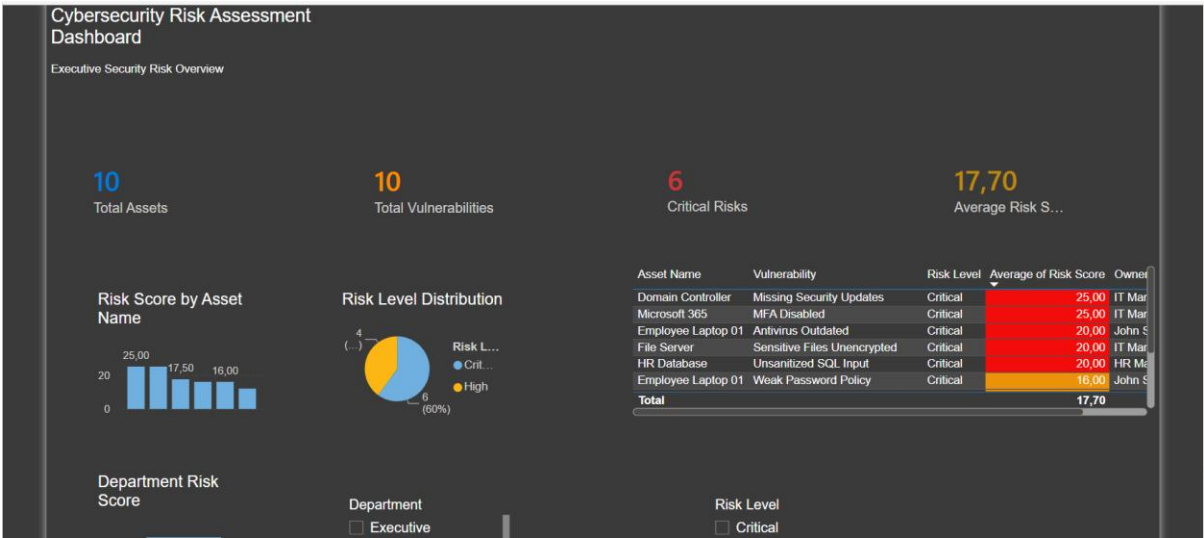
The dashboard provides executives with a centralised view of cybersecurity risk across organisational assets, vulnerabilities, and departments. By prioritising critical vulnerabilities, strengthening compliance, and implementing the recommended security controls, the organisation can reduce its overall risk exposure and improve resilience. Continued monitoring, timely remediation, and periodic reassessment will help sustain these improvements and strengthen the organisation’s overall security posture.

9. References

- National Institute of Standards and Technology. NIST Special Publication 800-30 Revision 1: Guide for Conducting Risk Assessments.
- International Organization for Standardization and International Electrotechnical Commission. ISO/IEC 27005:2022: Information security, cybersecurity and privacy protection — Guidance on managing information security risks.

10. Appendix

- **Appendix A:** Executive Dashboard



- **Appendix B:** Data Model

